

FortisAid Health Technologies
Policy Number: FTAID-POL-001
Version 1.0 | Effective: 20 Feb 2026

Document Control Page

Field	Details
Policy Title	Information Security Policy
Policy Number	FTAID-POL-SEC-PA-001
Author	Ivy Kiley
Policy Owner	Chief Information Security Officer
Reviewer	IT Security Committee (Group 2)
Approver	Chief Executive Officer
Version	1.0
Effective Date	19 th February 2026
Current Review Date	19 th February 2026
Next Review Date	19 th February 2026
ISO 27002:2022 Domain	Organizational Controls, Technological Controls, Physical Security, System and Application control
ISO 27002:2022 Sub-Domain	Information Security Policies, Asset Management,
ISO 27002:2022 Control	5.1, 5.9, 5.15, 7.1, 8.1, 8.2
Related Policies	Confidentiality and Data Protection Policy, Access Control Policy, Records Management Policy, Incident Reporting Policy, Network Security Policy
Approval Status	

Approval Evidence

Approver: Chief Executive Officer

Signature: _____

Date: _____

Purpose and Scope

Purpose

The purpose of this policy is to establish a comprehensive framework for the protection of FortisAid Health Technologies' information assets, while ensuring that the health-related data remains confidential, maintains integrity, and is available. This in compliance with healthcare regulatory and security standards, with the aim of mitigating threats such as unauthorized access.

Scope

This policy applies to:

- i. All FortisAid employees, contractors, consultants, volunteers, and third-party users working on behalf of FortisAid.
- ii. All information assets, including patient data, clinical systems, business systems, cloud platforms, networks, endpoints such as laptops and mobile devices, and medical applications.
- iii. All physical, digital, and cloud-based environments operated or managed by FortisAid.

FortisAid Context

FortisAid operates cloud-based healthcare platforms, Electronic Health Records (EHR), Remote Patient Monitoring (RPM) systems, and clinical analytics solutions that process sensitive Personal Health Information (PHI), requiring strict information security governance.

1. ISO 27002:2022 Alignment

ISO Domain	ISO Sub-domain	Control Number	How this policy addresses it
Organizational Controls	Information Security Policies	5.1	Establishes management-approved information security policies and governance framework.
Organizational Controls	Inventory of Information and Other Associated Assets	5.9	Requires identification, ownership, and risk assessment of information assets.
Organizational Controls	Access Control	5.15	Establish rules for authorized access and least privilege principles.
Physical Controls	Physical Security Perimeters	7.1	Mandates physical protections for information assets and environments
Technological Controls	User Endpoint Devices	8.1	Sets requirements for secure use of devices, including encryption and remote working.
Technological Controls	Privileged Access Rights	8.2	Controls assignment, monitoring, and revocation of elevated privileges

2. Threats and Key Risks (Healthcare Context)

Threats

- i. Ransomware attacks targeting hospital and healthcare infrastructure.
- ii. Insider threats, including accidental data leakage.
- iii. Cloud security misconfigurations.
- iv. Physical breaches i.e., theft of devices and unauthorized access to patient records and healthcare infrastructure

Key Risks to FortisAid

- i. Breach of patient confidentiality that leads to harm or loss of trust.
- ii. Disruption of clinical services impacting patient safety due to environmental hazards.
- iii. Regulatory fines and legal penalties under UK GDPR and FORTSAID regulations due to non-compliance.

3. Policy Statements / Requirements

3.1 Information Asset Management

Any information assets including databases and hardcopy records should be documented in an Information Asset Register (IAR) and allocated an Information Asset Owner (IAO) who oversees risk assessment and business continuity.

The assets should be categorized by the sensitivity e.g. confidential patient data and be secured both to satisfy the operational needs of NHP, UK GDPR of personal/special category data, and ISO of inventory and risk management.

Periodic audits of assets will be performed to ensure that the DSPT standards are met, such as anonymizing or pseudonymizing the assets when necessary to lower the chances of identification.

3.2 Access Controls and Security.

The access to information systems will be based on the least-privilege concept and IAOs-authorized role-based access. Patient data systems should have multi-factor authentication (MFA) and smart cards.

Unique and complex passwords that are not shared should be deployed; generic accounts must not be utilized unless the emergency case is approved.

Badges, codes or escorted access will be used to restrict physical access to security which are consistent with the ISO physical security perimeters.

The remote working process must be conducted with encrypted gadgets and connections; the storage of confidential data must be conducted exclusively with the agreement and the valid utilization of personal tools.

3.3 Data Protection and Transfers

Encryption of the special category data and personal data, both at rest and in transit, should be approved by SIRO, and the transfer of non-routine bulk data greater than 50 records should be encrypted.

Transfers out of UK/EEA ought to be complying with the UK GDPR protection; fax transfer of confidential information is not allowed.

Changes or new systems should be subject to Data Protection Impact Assessment (DPIAs) to ensure the compliance with Digital Technology Assessment Criteria (DTAC).

3.4 Incident Management and Business Continuity

All security incidents are to be notified within 24 hours under the Incident Reporting Policy of NHP and all the serious breaches notified to the ICO within 72 hours.

To ensure business continuity plans will be taken on the critical assets to make them available yearly and linked to the Risk Management Framework of NHP.

Forensic preparedness will be made through audit trails and preservation of evidence as well as preparations of investigations.

3.5 Physical and Environmental Security

Storage spaces for the information must be secured (e.g., locked compartments, fire precautions). Equipment disposal to be done should also include secured data destruction; re-use should be evaluated. There should be clear desk policy and safe disposal of waste to prevent unauthorized entry.

4. Roles and Responsibilities

Role	Responsibilities
Chief Executive Officer (CEO)	Final policy approval, executive sponsorship, and resource allocation
Chief Information Security Officer (CISO)	Policy ownership, governance, monitoring compliance, risk oversight
IT Security Manager	Implementation of security controls, monitoring, incident response
Clinical Systems Director	Security oversight of clinical platforms and patient systems
System Administrators	Secure system configuration, access control, patch management
All Staff	Compliance with policy, incident reporting, security best practices

5. Compliance and

Enforcement Monitoring

Activities

- i. Quarterly security audits and compliance reviews.
- ii. Continuous security monitoring by the Security Operations Center (SOC).
- iii. Evidence stored in secure FortisAid GRC and audit management systems.

Non-Compliance

Failure to comply with this policy results in disciplinary action, and can include termination of employment, legal action, and reporting to regulatory authorities where required.

Exceptions

All policy exceptions must be approved in writing by the CISO and formally reviewed quarterly.

6. Training and Awareness

- i. Mandatory completion of information security training within 30 days of onboarding.
- ii. Annual refresher training for all staff.
- iii. Role-based advanced training for system administrators, clinical staff, and security teams.

7. Review and Revision

This policy will be reviewed annually or in case of security incidents or data breaches, changes to the country's legislation, i.e., GDPR updates or FortisAid guidance, and organizational changes affecting information assets.

Next scheduled review: 21 February 2027.